

PROVA FINAL

- Entrega Sem prazo
- Pontos 40
- Perguntas 10
- Limite de tempo 60 Minutos
- Tentativas permitidas 2

Instruções

INSTRUÇÕES DA PROVA FINAL

- A prova tem a duração de 60 minutos.
- Ao clicar em PROVA FINAL, no menu “Testes” você iniciará a prova. Ao acessar a página com as questões, o tempo começa a ser contado.
- A prova é composta de 10 (dez) questões objetivas, sendo 04 (quatro) pontos cada.
- Ao final do teste não se esqueça de enviá-lo, clicando no botão “ENVIAR TESTE”. Só utilize esse botão quando tiver finalizado a avaliação.
- Se necessário, durante a prova, entre em contato pelo link “Atendimento”.
- Você terá 02 (duas) tentativas e, caso necessite de uma nova, será preciso solicitar a prova extra, que requer pagamento de taxa adicional.

Atenção: Todas as provas iniciadas e que não houverem sido submetidas serão automaticamente encerradas pelo sistema transcorridos os 60 minutos de duração.

Boa prova!

Histórico de tentativas

	Tentativa	Tempo	Pontuação
MANTIDO	Tentativa 2	6 minutos	36 de 40
MAIS RECENTE	Tentativa 2	6 minutos	36 de 40
	Tentativa 1	12 minutos	28 de 40

Pontuação desta tentativa: 36 de 40

Enviado 10 abr em 11:08

Esta tentativa levou 6 minutos.

Resposta correta



Pergunta 1

4 / 4 pts

Os modelos no contexto da engenharia de software evoluíram com o tempo para atender os diversos aspectos da dinâmica corporativa, assim como, as demandas do mercado. Cabe à organização compreender a natureza do projeto de software para adotar o método ou metodologia adequada.

Uma organização está adotando a metodologia Waterfall para o desenvolvimento de um software que será implantado em um projeto de sistemas embarcados. Neste sentido, houve uma preocupação da adoção dos requisitos de segurança para o projeto em questão. Neste sentido, é correto afirmar que a MELHOR fase que os requisitos de segurança deve ser adotados é na fase de:

☒ Design do Sistema

Correto. Nesta fase, requisitos específicos para o produto podem definidos.

☐ Implementação

☐ Análise de Requisitos

☐ Implantação do Sistema

Resposta correta



Pergunta 2

4 / 4 pts

A criptografia juntamente com certificados digitais, assim como, uma infraestrutura de chave pública (do inglês *Public Key Infrastructure* - PKI) é um método muito importante para a segurança do produto de software e amplamente adotado.

Uma organização resolveu adotar a assinatura de código (do inglês, *Code Sign*), que adota técnicas de criptografia em seu produto de software, e neste sentido, qual dos seguintes itens a assinatura de código não pode fornecer aos seus clientes?

☒ Garantia da ausência de vulnerabilidades.

Correto. A criptografia assimétrica e KPI não podem garantir a ausência de vulnerabilidades no software.

☐ Autenticação da origem.

☐ Prova de integridade do código.

☐ Garantia que o código é autêntico.

Resposta correta



Pergunta 3

4 / 4 pts

A remediação de vulnerabilidades é um dos pontos-chave da cultura DevSecOps, uma vez que lidamos diretamente com o débito técnico de segurança.

Uma Squad irá remediar uma biblioteca com a seguinte característica: a biblioteca vulnerável está na versão 1.6.9 e a versão que não possui vulnerabilidade que é requerido o upgrade é a versão 6.6.10. Neste sentido é correto afirmar:



O upgrade da biblioteca para remediação de vulnerabilidades terá impacto para aplicação, uma vez, que se trata de uma mudança de versão quanto à semântica de patch. Requer teste de regressão.



O upgrade da biblioteca para remediação de vulnerabilidades terá impacto para aplicação, uma vez, que se trata de uma mudança de versão quanto à semântica de Major. Requer teste de regressão.

Correto. Há uma mudança na semântica de Major, o que geralmente incorre em Break Change, portanto, se faz necessário o Teste de Regressão.



O upgrade da biblioteca para remediação de vulnerabilidades não terá impacto para aplicação, uma vez, que se trata de uma mudança de versão quanto à semântica de patch. Não requer teste de regressão.



O upgrade da biblioteca para remediação de vulnerabilidades não terá impacto para aplicação, uma vez, que se trata de uma mudança de versão quanto à semântica de Major. Não requer teste de regressão.

Resposta correta



Pergunta 4

4 / 4 pts

A proteção das aplicações Web é uma parte importante quando estamos lidando com falhas de segurança, assim como, técnicas adequadas para identificá-las.

Uma empresa no mesmo nicho de negócio que uma determinada empresa passou por um incidente de segurança em seu E-Commerce. O que foi observado é que o SAST e o DAST implementados não revelaram nenhuma vulnerabilidade, contudo, após a investigação, observou-se que havia uma falha no fluxo de autorização da aplicação. Como lição aprendida a partir do alheio, no contexto da falha descoberta, quais os MELHORES métodos podem ser utilizados para detectar a falha e reduzir o risco?



A organização pode adotar MFA e CAPTCHA, que irá reduzir o risco contra este tipo de falha.



A organização pode adotar revisão manual de código e Teste de Intrusão (Pentest), que podem ajudar a identificar este tipo de falha.

Correto. A revisão manual de código e Teste de Intrusão (Pentest), são mecanismos que podem ajudar a detectar este tipo de falha.



A organização pode adotar uma solução de Firewall e WAF (Web Application Firewall), que protegem a aplicação contra este tipo de falha.



A organização pode adotar WAF e RASP no modo de monitoramento, que podem ajudar a identificar este tipo de falha.

Resposta correta



Pergunta 5

4 / 4 pts

A gestão de mudanças é um processo relevante para controlar como alterações no ambiente de produção podem controlados para minimizar impactos sobre a disponibilidade dos produtos.

Uma empresa resolveu adotar a gestão de mudanças devido a constantes alterações no ambiente produtivo que culminaram em indisponibilidade e queda na receita. Após três meses de adoção obtiveram excelentes resultados e o atendimento ao SLA foi cumprido e interrupções, de fato, minimizados. Contudo, um trade-off foi identificado, que impactou no prazo nas entregas das equipes, provocando atrasos, implicando em processos burocráticos e produtividade afetada. Das opções abaixo, qual a **MELHOR** forma de lidar com este problema?

☐

Adotar a automação de processos e automatização de tarefas, minimizando o risco, de forma que as mudanças caiam na categoria de Mudança Normal.

☐

Adotar um processo de gestão de mudanças baseado em boas práticas, por exemplo, ITIL.

☒

Adotar a automação de processos e automatização de tarefas, minimizando o risco, de forma que as mudanças caiam na categoria de Mudança Padrão.

Correto. Tanto a corretude da prática quanto à categoria são almejados e podem contribuir para minimizar o problema do contexto apresentado.

☐

Rever a adoção do processo de gestão de mudanças, uma vez que há impactos para o sucesso do cliente.

Resposta correta



Pergunta 6

4 / 4 pts

Testes de Software são amplamente adotados como parte das práticas do processo de DevSecOps, sendo abordados tanto os testes tradicionais da engenharia de software quanto aqueles da perspectiva de Test-Driven Security. Estes testes buscam tanto melhorar a qualidade do software quanto melhorar a postura de segurança do software.

Um novo integrante da equipe de desenvolvimento de software acabou de ingressar em uma Squad. Você foi nomeado como um Security Champion. Ao tomar contato com a trilha de desenvolvimento seguro, durante um questionário de compreensão dos temas iniciais, o novo integrante ficou com dúvida, pois não obteve êxito na seguinte questão de avaliação de conhecimento: “*Quando o teste de segurança é realizado com conhecimento completo do código-fonte, como é chamado?*”. Qual a alternativa correta o novo integrante deveria considerar?

☒

White-Box Testing

Correto. Ferramentas de teste de segurança que possuem acesso ao código-fonte são denominadas White-Box Testing.

☐

Teste Unitário

☐

Black-Box Testing

☐

Code-Review (Revisão de Código)

Resposta correta



Pergunta 7

4 / 4 pts

As aplicações precisam de lidar com o tratamento de diversas informações sigilosas e sensíveis para a própria operacionalização. Informações como chave de criptografia simétrica, chave privada, senhas, entre outros, nos quais são majoritariamente cunhados como “segredos (ou secrets, em inglês)”, podem desembocar em grandes riscos para a organização se não forem tratados com segurança.

Das opções abaixo, qual seria uma abordagem, no mínimo razoável, contudo, menos problemática para lidar com a gestão de segredos em uma aplicação crítica de negócio?

- ☐ Adotar os segredos em arquivos README garantindo o privilégio mínimo e necessidade de saber.
- ☒ Armazenar os segredos em variáveis de ambiente criptografadas.

Correto. Em caso de uso de variáveis de ambiente para armazenamento de segredos, estas devem ser criptografadas.

- ☐ Incluir os segredos no código-fonte garantindo o privilégio mínimo e necessidade de saber.
- ☐ Usar apropriadamente arquivos .ENV (variáveis de ambiente) com restrições de acesso.

Resposta incorreta



Pergunta 8

0 / 4 pts

Há um conceito fortemente considerado no desenvolvimento seguro de aplicações que é SD3+C (Secure by Default, Secure by Design e Secure by Deployment e Communication). Cada contexto de segurança possui uma série de desdobramentos que são adotados, inclusive, como requisitos de segurança.

Uma organização está planejando um meio de garantir, ainda que de forma tecnológica, como parte de seus processos de segurança, que o paradigma de Secure by Default, seja um requisito para o Pipeline de desenvolvimento de software. Neste sentido, a empresa pode adotar qual dos seguintes para satisfazer este requisito:

- ☐ DAST
- ☒ Test-Driven Security

Incorreto. Test-Driven Security não garante a adoção do paradigma Secure by Default.

- ☐ IAST
- ☐ RASP

Resposta correta



Pergunta 9

4 / 4 pts

IAST (muitas vezes associado como a junção de SAST e DAST) é uma tecnologia que adota a instrumentação de software como forma de operação. Uma porção de código é adicionada ao aplicativo para coletar dados e realizar análises, integrando lógica de coleta ao código.

Das opções abaixo, é falsa a afirmativa:

☐ No modelo IAST Ativo, é adotado um scanner da Web como parte do processo de teste.



No modelo IAST Passivo, é adotado um módulo de DAST como parte do processo de teste e um agente de detecção.

Correto. O IAST Passivo possui apenas o agente e detecção.

☐ As ferramentas de IAST não devem ser utilizadas em ambiente de Produção.

☐ As ferramentas IAST são ditas Gray-Box.

Resposta correta



Pergunta 10

4 / 4 pts

Testes de Software são amplamente adotados como parte das práticas do processo de DevSecOps, sendo abordados tanto os testes tradicionais da engenharia de software quanto aqueles da perspectiva de Test-Driven Security. Estes testes buscam tanto melhorar a qualidade do software quanto melhorar a postura de segurança do software.

Uma empresa realizou um teste de segurança avaliando as bibliotecas de terceiros incorporados ao software. Para atender aos requisitos de segurança ela aplicou correções em uma determinada biblioteca crítica. Qual teste a organização deve adotar para garantir que esta correção não tenha impactos que podem causar interrupção no software?

☐ Teste Unitário

☐ Teste de Intrusão (Pentest)

☒ Teste de Regressão

Correto. O Teste de Regressão é amplamente utilizado para avaliar eventuais impactos que podem “quebrar” a aplicação após a remediação vulnerabilidades técnicas para o contexto apresentado.

☐ Teste de Fuzzing

Pontuação do teste: 36 de 40